

Как проверить готовность к аттестации по Приказу ФСТЭК № 117

Если планируется аттестация информационной системы по требованиям [приказа ФСТЭК № 117](#) и требуется оценить готовность инфраструктуры или затраты — поможет наша подборка, в которой мы свели все самое важное в одном месте.

За основу мы взяли самый распространенный тип ИС. Рассматриваем систему класса КЗ, развернутую на базе нескольких физических и (или) виртуальных серверов. У нее есть веб-интерфейс, а в контур входят рабочие места как конечных пользователей, так и администраторов.

Организационные требования

Первое что необходимо сделать — **внедрить в компании процессы по информационной безопасности**. Во время аттестации для оценки запрашиваются соответствующие организационно-распорядительные документы.



Обратите внимание: приведенный перечень является ориентировочным и достаточным для большинства типовых информационных систем. Нормативная база допускает адаптацию требований [Методического документа](#) под специфику конкретного объекта и принятых в компании подходов: возможно как разделение отдельных пунктов требований, так и консолидация нескольких регламентов в единые корпоративные стандарты безопасности.

- ① Политика информационной безопасности.
- ② Регламент управления уязвимостями.
- ③ Регламент управления обновлениями.
- ④ Регламент управления конфигурациями.
- ⑤ Регламент мониторинга информационной безопасности.
- ⑥ Регламент обнаружения и предотвращения вторжений.
- ⑦ Регламент выявления и реагирования на инциденты ИБ.
- ⑧ Регламент предоставления доступа в Интернет.
- ⑨ Регламент защиты мобильных устройств (если они используются).
- ⑩ Регламент разработки безопасного ПО (если в рамках ИС ведется разработка).
- ⑪ Регламент обеспечения физической защиты.
- ⑫ Регламент обеспечения непрерывности функционирования.

- 13 Регламент повышения уровня знаний и информированности пользователей по вопросам информационной безопасности.
- 14 Регламент контроля уровня защищенности информации.
- 15 Порядок управления учетными записями пользователей и доступами (включая матрицу доступа).
- 16 Порядок защиты информации ограниченного доступа.
- 17 Порядок защиты конечных устройств.
- 18 Порядок предоставления удаленного доступа.
- 19 Порядок использования средств криптографической защиты информации.
- 20 Порядок предоставления доступа подрядным организациям.
- 21 Порядок резервного копирования информации.
- 22 Порядок антивирусной защиты.
- 23 Перечень разрешенного и (или) запрещенного ПО.
- 24 Инструкции администратора информационной безопасности, администратора и пользователя.

Технические требования

Для защиты аттестуемой информационной системы нужно не только подготовить регламенты, но также развернуть и настроить правильные технические инструменты. Ниже мы собрали необходимый минимум средств защиты информации (СЗИ) и показали, какими готовыми услугами от Selectel можно закрыть эти задачи.

Тип СЗИ	Чем может помочь Selectel
1 Операционная система, сертифицированная по требованиям безопасности. Применение стандартной ОС с наложенными средствами защиты от несанкционированного доступа (СЗИ от НСД) формально допускается, но не рекомендуется.	ОС Astra Linux Special Edition , РЕД ОС или Secret Net LSP (как дополнение к другим дистрибутивам) Secret Net Studio — для Windows
2 Средства двухфакторной аутентификации. Их внедрение обязательно как минимум для привилегированных пользователей. В качестве решения можно использовать как отдельные MFA-продукты, так и комплексные системы управления доступом класса IDM или PAM.	Мультифактор

③	Средства антивирусной защиты. Помимо базовых хостовых решений, необходимо предусмотреть проверку электронной почты (если она входит в периметр ИС) и фильтрацию сетевого трафика.	Kaspersky Endpoint Security
④	Многофункциональный межсетевой экран (NGFW). Инструмент необходим для: — сегментирования сети, — антивирусной проверки трафика, — выявления вторжений, — обеспечения безопасности вплоть до прикладного уровня (L7) модели OSI и защиты от DDoS-атак. В качестве альтернативы допускается развернуть комплекс отдельных СЗИ: — межсетевой экран (МЭ), — потоковый антивирус (AB3), — систему обнаружения вторжений (COB) и WAF. При этом задачу по противодействию DDoS-угрозам можно делегировать провайдеру.	UserGate (с модулем COB), дополнительно SolidWall и защита от DDoS
⑤	Средство выявления и анализа уязвимостей.	Поиск уязвимостей
⑥	Средства криптографической защиты. Их применение необходимо в том случае, если взаимодействие с ИС осуществляется по открытым каналам связи.	ГОСТ-VPN
⑦	Средство резервного копирования информации.	Кибер Бэкап

Тип СЗИ

Чем может помочь Selectel

⑧

Средства защиты среды виртуализации.

Их развертывание необходимо в том случае, если инфраструктура информационной системы построена на базе виртуальных машин.

[Аттестованное облако](#)

⑨

Сертифицированная СУБД или специализированные средства ее защиты. Использовать такие решения необходимо в том случае, если для обработки информации применяются системы управления базами данных.

СУБД из состава сертифицированной [ОС Astra Linux Special Edition, РЕД ОС](#)

Подробнее об информационной безопасности как услуге можно узнать [на странице продуктов Selectel](#).